

WebSocket Security Testing Checklist

1. WebSocket Discovery

- Search JavaScript files for new WebSocket().
- Search for wss:// and ws:// endpoints.
- Inspect the browser Network tab for Upgrade requests.
- Review Burp Suite WebSockets history.
- Identify SockJS, Socket.IO, SignalR, GraphQL subscriptions, and mobile application WebSocket endpoints.

2. Handshake Testing

- Modify the Upgrade header.
- Modify the Connection header.
- Remove or alter the Sec-WebSocket-Key header.
- Modify the Sec-WebSocket-Version header.
- Remove or change the Origin header.
- Modify the Host header.
- Send duplicate or malformed headers.
- Test invalid WebSocket versions.

3. Authentication Testing

- Connect without authentication.
- Use expired or another user's token.
- Remove the Authorization header or cookies.
- Modify JWTs or use unsigned JWTs where applicable.
- Replay old authentication tokens.
- Verify whether connections remain active after logout.
- Test session handling including logout, password reset, expiration, fixation, hijacking, and revoked sessions.

4. Authorization Testing

- Horizontal privilege escalation: access another user's channels, messages, notifications, rooms, and IDs.
- Vertical privilege escalation: access administrator channels, internal events, moderator actions, and administrator-only functionality.

5. Message Manipulation

- Parameter tampering: modify, remove, add, or duplicate JSON fields; test negative, large, floating-point, null, and empty values.
- Type confusion: send incorrect data types such as string instead of integer, array instead of object, null, and Boolean values.